AI Working Group (AI WG) Meeting Notes
September 13, 2024

Agenda

- Status update on working group, sub-working opportunities, and collaborative brainstorm.

Action Items

- Reach out to participants to see who would be interested in tackling some of the tasks mentioned and forming sub-working groups.

Summary

- **Meeting Overview**: The AI Working Group convened on September 13, 2024, to discuss AI-related topics, including sub-working groups, CWE entry development.
- **Formation of Sub-Working Groups**: The group emphasized the need to form sub-working groups to manage specific tasks, ensuring multiple owners for continuity. Two subgroups were proposed by Alec Summers.
- **Development of Entry**: Much of the time was applied to developing potential consequences, mitigations, detection, applicable platforms, and modes of introduction for a new CWE entry being drafted by the group.
- **Future Tasks and Submissions**: Future tasks include crafting updated solutions for existing weaknesses relevant to AI, especially for the continued development of a CWE entry for Improper [Missing or Incorrect] Neutralization of Input Used for LLM Prompting," and the finalization of the entry for submission on October 24.

Meeting Notes

<u>Subgroup</u>

Alec Summers presented and facilitated the AI WG meeting, and began with a discussion of the WG and proposed subgroup opportunities for WG participants.

Mission of the AI WG is to advance the CWE's coverage of AI-related weaknesses.
Two proposed subgroups:

1. Improving existing CWE content that is relevant to an AI system
2. Developing new CWE entries to cover AI related gaps in the CWE corpus.

Not enough participants were identified yet, so that the subgroups remain unformed.

<u>New Entry Development</u>

Alec Summers presented the new CWE elements that required before an entry can be published. A worksheet for the "Improper [Missing or Incorrect] Neutralization of Input Used for LLM Prompting" was presented.

Proposal from CWE entry submitters from Praetorian to identify various CWE relationships with the neutralization of input for LLM prompting.

- It is unclear whether this entry should be a child of CWE-94, as CWE-77 may be more appropriate.

Common Consequences Worksheet, "Improper [Missing or Incorrect] Neutralization of Input Used for LLM Prompting"

Alec Summers opened the floor to comments and notes for consequences related to this CWE entry development appearing in real world vulnerabilities.

Consequence 1:
Impact: Execute Unauthorized Code or Commands
Discussion: Eric Galinkin mentioned that the consequences depend on the system that the model is integrated into, such as a chatbot or a code interpreter, which could result in remote code execution (RCE). The consequences remain entirely contextual.

Consequence 2:
Impact: "Varies by Context"
Discussion: Member mentioned a subtree logic to delineate use cases. Members noted we cannot cover all possibilities, however. Member recommended language to researchers for delineation. Member mentioned the inclusion of threat modeling for each specific AI implementation.

Potential Mitigations Worksheet, "Improper [Missing or Incorrect] Neutralization of Input Used for LLM Prompting"

Mitigation 1: Threat Modeling for Each Specific AI Implementations.
Discussion: Member mentioned that threats don't come into play until weakness leads into a vulnerability. It is very context dependent; context is where the threat comes into.
Member mentioned that he worked in organizations where security is involved in production from the initial design stages.

Mitigation 2: Make Sure the model is "narrowed enough"

Discussion: Member proposed fine tuning an LLM to the specific or narrowed down use case. Member mentioned that fine tuning is part of the production process in the design stages. They also commented that the barrier to entry on this mitigation is higher than supposed. "Narrowing a scope on an AI model is a task upon itself." Member agreed, saying that retraining a model is beyond most people's ability.

Member stated that there are mitigations that are varied in their realistic implementation, but they should still be captured.

Detection Methods Worksheet

Alec Summers opened the floor to comments on the detection methods worksheet. The slide was populated with methods for detection validation, which two members agreed were valid for the current CWE entry draft. The conversation moved on to seeing if there were any other detection methods applicable. No comment at the time

Applicable Platforms Worksheet

Previous discussions added the AI/ML Applicable Platform element. A discussion ensued attempting to parse the languages and architecture names that were applicable to applicable platforms for AI/ML . Member mentioned that there are some emerging stacks that could be leveraged to build new platforms, and that these should be tracked. Member mentioned that the schema for platforms may need to be expanded.

Modes of Introduction Worksheet

Alec Summers clarified that this worksheet was meant to show when or how the developer introduces the weakness to the system.

Mode 1:

SDLC phase: design and implementation. Member asked: who is the consumer of this current work that we are developing? Is it the people that are using AI or is it the people that is creating AI? Member suggested it might be context dependent.

Mode 2:
There is no training mode in the schema as such, but the SDLC phase was named as the AI development life cycle. Member mentioned that training is part of development; "isomorphic to development". Member mentioned that training is also related to fine tuning.

Mode 3:

Training in the SDLC phase can be used to introduce weaknesses. The developer is limited in their ability to do this because of the difficulty and costs associated.

Mode 4:

System configuration in the SDLC phase, such as where model parameters can be manipulated.

Mode 5:

Integration and bundling in the SDLC phase. Member mentioned that these aspects would need to be fleshed out more.

Observed Examples Worksheet

Alec outlined the goal for this worksheet: a curated list of real world examples where this weaknesses is observed. He briefly went over worksheets for ***Demonstrative Examples***, which included theoretical educational examples in an academic context, as well as the ***References Worksheet***.

Next Steps

Continue to develop and draft remaining content. MITRE to move submission of CWE to "Accepted" and later to "Full Details Accepted." MITRE to continue coordinating with submitter and AI WG to develop this submission. Discussion to take place in CDR. Next CWE release scheduled for October 24.

No further comment from group. Meeting adjourned.